

Niagara AX Hardening Guide

Tips to Secure a Niagara AX System

Contents

Introduction.....	3
Passwords.....	3
• Change the default Platform Credentials.....	4
• Use the Password Strength Feature.....	5
• Enable the Account Lockout Feature.....	7
• Expire Passwords.....	8
• Use the Password History.....	10
• Use the Password Reset Feature.....	11
• Leave the “Remember These Credentials” Box Unchecked.....	12
Account Management and Permissions.....	13
• Use a Different Account for Each User.....	13
• Use Unique Service Type Accounts for Each Project.....	14
• Disable Known Accounts When Possible.....	14
• Set Up Temporary Accounts to Expire Automatically.....	14
• Change System Type Account Credentials.....	15
• Assign the Minimum Required Permissions.....	16
• Use Minimum Possible Number of Super Users.....	16
• Require Super User Permissions for Program Objects.....	17
• Use the Minimum Required Permissions for External Accounts.....	17
Authentication.....	17
• Use “Digest” Authentication in the FoxService.....	18
• Set the FoxService Legacy Authentication to “Strict”.....	19
• Use “cookie-digest” Authentication in the WebService.....	19
TLS & Certificate Management.....	20
• Enable Platform TLS Only (3.7 or higher).....	21
• Enable Fox TLS Only (3.7 or higher).....	22
• Enable Web TLS Only.....	24
• Enable TLS on Other Services.....	25
• Set Up Certificates.....	25
JACE-8000 Settings.....	26
• System Password Management.....	26
• Use TLS to set the system passphrase.....	26
• Choose a truly strong passphrase.....	26
• Protect the system passphrase.....	27
• Disable SSH/SFTP.....	27
Additional Settings.....	28
• Disable FTP and Telnet.....	29
• Disable Unnecessary Services.....	30
• Configure Necessary Services Securely.....	30
• Blacklist Sensitive Files and Folders.....	30
• Update Niagara AX to the Latest Release.....	31
External Factors.....	32
• Install JACEs in a Secure Location.....	32
• Make Sure that Stations Are Behind a VPN.....	32

Introduction

This document describes how to implement security best practices in a Niagara AX system. While it is impossible to make any system completely impenetrable, there are many ways to build up a system that is more resistant to attacks. In particular, this document describes how you can help make a Niagara AX system more secure by carefully configuring and using:

- Passwords
- Accounts and Permissions
- Authentication
- TLS and Certificate Management
- JACE-8000 Settings
- Additional Settings
- External Factors

Please note that while all of these steps should be taken to protect your Niagara AX system, they do not constitute a magic formula. Many factors affect security – and vulnerabilities in one area can affect security in another; it doesn't mean much to configure a system expertly if your JACE is left physically unsecured where anyone can access it.

Passwords

The Niagara AX system uses passwords to authenticate “users” to a station or platform. It is particularly important to handle passwords correctly. If an attacker acquires a user's password, they can gain access to the Niagara AX system and will have the same permissions as that user. In the worst case, an attacker might gain access to a Super User account or platform account and the entire system could be compromised.

Here are some of the steps that can be taken to help secure the passwords in a Niagara AX system:

- Change the Default Platform Credentials
- Use the Password Strength Feature
- Enable the Account Lockout Feature
- Expire Passwords
- Use the Password History
- Use the Password Reset Feature
- Leave the “Remember These Credentials” Box Unchecked

Change the default Platform Credentials

Many controllers are shipped with the following default platform daemon credentials:

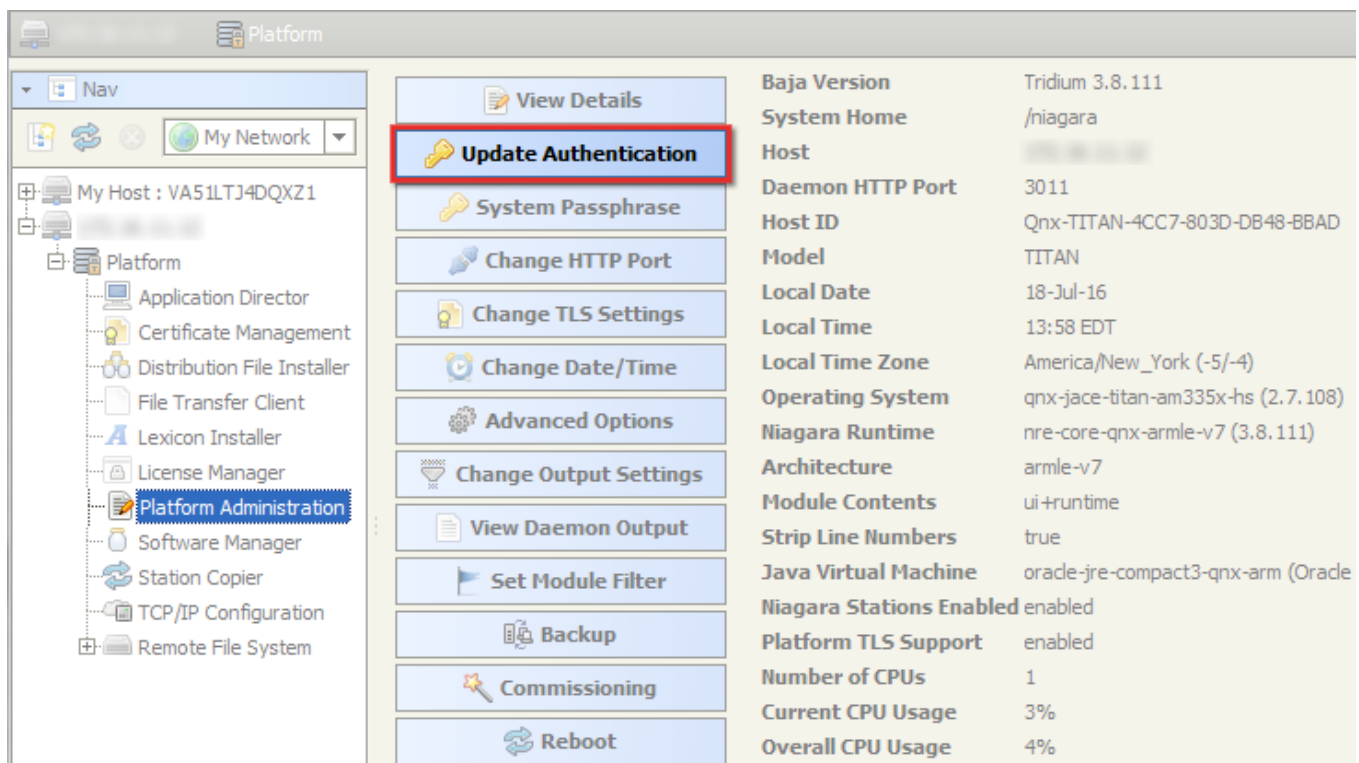
Username: tridium

Password: niagara

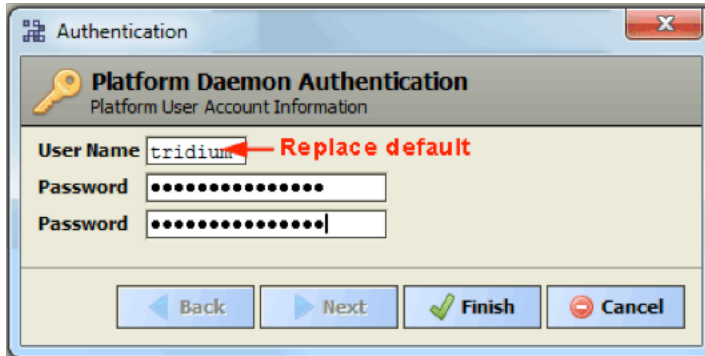
These default credentials are the same for all JACEs, and make it easy to set up a new JACE and quickly connect to it. However, these credentials provide the highest level of access. If left unchanged, anyone who knows the default credentials could potentially make a platform connection and gain complete control of the controller. It is essential to change the default credentials as soon as possible, before exposing the JACE to an open network.

Use the following steps to change the platform credentials:

1. Open a platform connection to the JACE and go to the Platform Administration view.



2. Click the "Update Authentication" button. An authentication dialog box will appear.



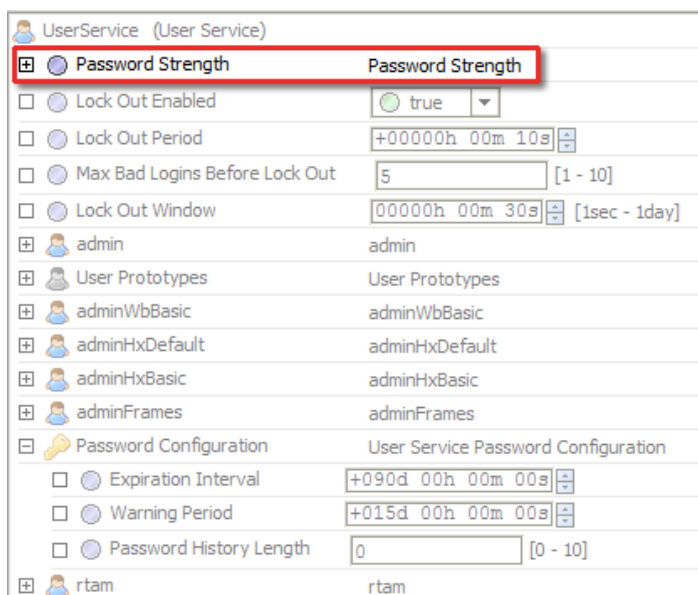
3. Enter the new credentials, and click “Finish.” The platform daemon credentials are updated. Note that the “Finish” button is available only if the two Password fields match.

Use the Password Strength Feature

Not all passwords are equally effective. Ensuring that users are choosing good, strong passwords is essential to securing a Niagara AX system. NiagaraAX-3.8, 3.7u1, 3.6u4 and 3.5u4 require strong passwords, by default. In NiagaraAX-3.7u1, 3.6u4 and 3.5u4, this is enforced by the “Require Strong Passwords” property on the UserService, and the definition of “strong” is hardcoded. If you are using a version of Niagara AX that does not require strong passwords by default, you should change the settings, as described below.

Configure the Niagara AX UserService to require strong passwords as follows:

1. Go to the station’s UserService’s property sheet.
2. Set the “Require Strong Passwords” property to “true.”



3. Save the changes.

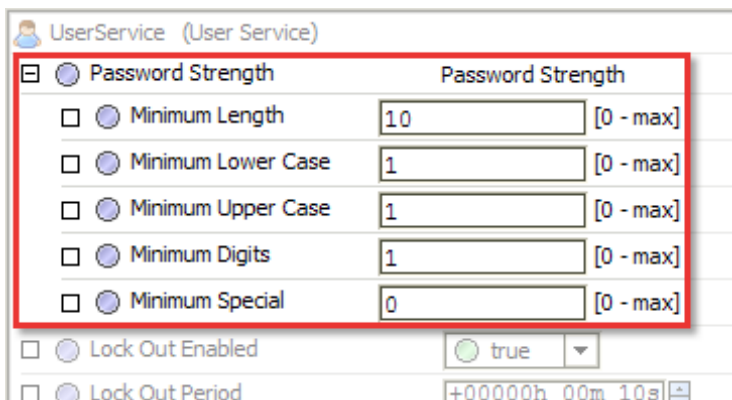
NOTE: This does not force a user to change weak passwords to strong passwords. If a user changes their password after this property is set to true, they will be required to use a strong password. Also, in older systems it may be necessary to task users with changing their own passwords or have a system administrator change all user passwords.

In NiagaraAX-3.8, password strength is enforced by the “Password Strength” property on the UserService, and the required password strength can be customized to meet the needs of each particular system. By default, passwords are required to be at least 10 characters in length, and contain at least 1 digit, 1 uppercase and 1 lowercase character. At the time of the writing of this document, this is the recommended industry standard for most applications. However, systems with higher security requirements can configure the “Password Strength” property to require a password strength that meets their needs.

Note that while password strength can be increased, it shouldn’t be reduced.

To change the required password strength, follow the steps described below.

1. Go to the station’s UserService’s property sheet.
2. Expand the “Password Strength” property, and edit the fields as appropriate.



Password Strength	
☐ Minimum Length	10 [0 - max]
☐ Minimum Lower Case	1 [0 - max]
☐ Minimum Upper Case	1 [0 - max]
☐ Minimum Digits	1 [0 - max]
☐ Minimum Special	0 [0 - max]
☐ Lock Out Enabled	true
☐ Lock Out Period	+000000h 00m 10s

3. Save the changes.

Note: This does not force a user whose password no longer meets the password strength requirement to change their passwords. If that user changes their password after the password strength requirements are modified, their new password will have to meet the new requirements.

Strong Passwords

In NiagaraAX-3.7 or newer systems, user accounts can be flagged to require the user to change their password on their next login. When “Require Strong Passwords” is set to true, users are required to choose passwords that are at least eight characters that are not ALL characters or ALL digits.

Stronger Passwords

Even with the “Required Strong Passwords” option enabled, there are some passwords that are stronger than others. It is important to educate users on password strength. Password strength requirements are not sufficient to ensure that actually strong passwords are used. For example, “Password10” satisfies all the requirements, but is actually a weak, easily crackable password. When creating a password, the following guidelines can help generate stronger passwords:

- A random string of characters, including digits and uppercase, lowercase and special characters, (e.g. s13pj96t!cD) is typically a strong password. However, these can be hard to remember.
- A long, nonsensical sentence (e.g. "I happily tarnished under 21 waterlogged potatoes, which meet up on Sundays") can be used as is. For systems that restrict password length, it can be contracted to include only the first character of each word (e.g. "Ihtu21wp,wmuoS"). These are difficult for attackers to guess, but are typically easy (albeit silly) for users to remember.

Note: when picking a sentence as a passphrase, it is best to avoid well-known phrases and sentences, as these may be included in dictionary attacks (e.g. "Luke, I am your father").

- A string of random words (e.g. "coffee Strange@ Halberd 11 tortoise!") provides a much longer password than a single word or a random string of characters. However, password crackers are becoming more aware of this technique, and inserting few random numbers and symbols in there can help.

Remember, a good password is easy for a user to remember, but difficult for an attacker to guess.

Enable the Account Lockout Feature

The user lockout feature allows the UserService to lock out a user after a specified number of failed login attempts. That user is not able to log back in to the station until the lockout is removed. This helps protect the Niagara AX system against attackers trying to guess or "brute force" users' passwords.

Account Lock Out is enabled by default, but if it is not currently enabled, you can enable it as described below:

1. Go to the station's UserService's property sheet.
2. Set the "Lock Out Enabled" property to true.

UserService (User Service)	
⊕ Password Strength	Password Strength
☐ Lock Out Enabled	☒ true
☐ Lock Out Period	+00000h 00m 10s
☐ Max Bad Logins Before Lock Out	5 [1 - 10]
☐ Lock Out Window	00000h 00m 30s [1sec - 1day]
⊕ admin	admin
⊕ User Prototypes	User Prototypes
⊕ adminWbBasic	adminWbBasic
⊕ adminHxDefault	adminHxDefault
⊕ adminHxBasic	adminHxBasic
⊕ adminFrames	adminFrames
⊕ Password Configuration	User Service Password Configuration
☐ Expiration Interval	+090d 00h 00m 00s
☐ Warning Period	+015d 00h 00m 00s
☐ Password History Length	0 [0 - 10]
⊕ rtam	rtam

3. Adjust the other lockout properties as necessary.

- **Lock Out Period.** This determines how long the user is locked out for. Even short periods (for example, 10 seconds) can be quite effective at blocking “brute force” attacks without inconveniencing users. However, more sensitive systems may warrant a longer lockout period.
- **Max Bad Logins Before Lock Out.** This determines how many login failures are required before locking out the user.
- **Lock Out Window.** The user is only locked out if the specified number of login failures occurs within the time set in the Lock Out Window. This helps separate suspicious activity (for example, 10 login failures in a few seconds) from normal usage (for example, 10 login failures over a year).

4. Save the changes.

Expire Passwords

Starting in NiagaraAX-3.7, user passwords can be set to expire after a specified amount of time or on a set date. This ensures that old passwords aren't kept around indefinitely. If an attacker acquires a password, it is only useful to them until the password is changed. You need to make sure that expiration settings are configured on the Password Configuration property sheet as well as on individual user properties.  Password Configuration

Password Expiration: Password Configuration Property Sheet

Configure general password expiration settings in the UserService property sheet, as described below:

1. Go to the UserService's property sheet and expand the “Password Configuration” property.
2. Configure the expiration settings as necessary.
 - **Expiration Interval.** This property setting determines how long a password is used before it needs to be changed. The default is 365 days. You should change this to a lower value; ninety days is standard for many situations. NOTE: You must also set individual user password expiration dates (See Password Expiration: Edit Users dialog box).
 - **Warning Period.** Users are notified when their password is about to expire. The Warning Period specifies how far in advance the user is notified. Fifteen days generally gives the user enough time to change their password.

UserService (User Service)	
☒ Password Strength	Password Strength
☐ Lock Out Enabled	☒ true
☐ Lock Out Period	+000000h 00m 10s
☐ Max Bad Logins Before Lock Out	5 [1 - 10]
☐ Lock Out Window	000000h 00m 30s [1sec - 1day]
☒ admin	admin
☒ User Prototypes	User Prototypes
☒ adminWbBasic	adminWbBasic
☒ adminHxDefault	adminHxDefault
☒ adminHxBasic	adminHxBasic
☒ adminFrames	adminFrames
☒ Password Configuration	User Service Password Configuration
☐ Expiration Interval	+090d 00h 00m 00s
☐ Warning Period	+015d 00h 00m 00s
☐ Password History Length	0 [0 - 10]
☒ rtam	rtam

3. *Save the changes.*

Password Expiration: Edit Users Dialog Box

Password expiration **must also be enabled on each user**. This property is also available, by user, from the UserSer-vice property sheet but it may be more conveniently configured from the User Manager view, as described below:

To enable user password expiration, do the following:

1. *Select the User Manager view on the UserService (Station > Config > Services > UserService).*
2. *In the User Manager view, select one or more users and click the Edit button to open the Edit dialog box.*

Name	Full Name	Enabled	Expiration	Permissions	Network User	Prototype Name	Language	Password
rtam	River Tam	true	31-Jul-16		false			--password
cnewman	Claire Newman	true	31-Jul-16		false			--password

Name

rtam

Full Name

River Tam

Enabled

☒ true

Expiration

☐ Never Expires
 ☒ Expires On

31-Jul-2016 11:59 PM EDT

Permissions

☐ Super User (access entire station, file system)

Network User

☐ false

Prototype Name

Language

Password

Password

Confirm

Email

Cell Phone Number

Facets

Time Format

(default)

Unit Conversion

None

Nav File

null

Force Password Reset

☒ true

Password Expiration

☐ Never Expires
 ☒ Expires On

31-Jul-2016 11:59 PM EDT

- Choose "Expires On" for the Password Expiration option and set the expiration date at least 15 days into the future or perhaps equal to what you set for the "Password Configuration" Warning Period property.

NOTE:

- The default user "Password Expiration" property value is "Never Expires". To create new users with expiring passwords enabled, set the Password Configuration "Expiration" property (UserService > User Prototypes > Default Prototype > Password Configuration) to "Expires On" under the "Default Prototype" but be sure to actually set the "Expires On" date for each user.
 - You could set the "Expires On" date to an arbitrary date far enough into the future that the user will likely have logged into the system before expiring and also set the "Force Reset At Next Login" to true so the user is forced to change their password on first login. This would then get their expiration in sync.
- Save the changes. The next time the user changes their password, the expiration date is automatically updated to the UserService's "Expiration Interval" added to current date and time.

Use the Password History

Starting in NiagaraAX-3.7, the UserService can be configured to remember users' previously used passwords. This password history is used to ensure that when a user changes his password, he or she does not choose a previously used password. Much like the password expiration feature, the password history helps prevent users from using passwords indefinitely. The default setting of "0" should always be changed to a reasonable number for your system.

To enable password history, do the following:

1. Go to the *UserService's* property sheet.
2. Expand the “Password Configuration” property.

The screenshot shows the 'UserService (User Service)' property sheet. Under the 'Password Configuration' section, the 'Password History Length' property is set to 5, which is highlighted with a red rectangular box. Other visible properties include 'Password Strength', 'Lock Out Enabled' (true), 'Lock Out Period' (+00000h 00m 10s), 'Max Bad Logins Before Lock Out' (5), and 'Lock Out Window' (00000h 00m 30s).

Set the “Password History Length” property to a non-zero value. This determines how many passwords are remembered. The maximum password history length is 10.

Use the Password Reset Feature

Starting in NiagaraAX-3.7, you can force users to reset their password. This is particularly useful when creating a new user. The first time a user logs in, he or she can create a brand new password known only to that user. The password reset feature is also useful to ensure that a new password policy is enforced for all users. For example, if a station is changed to require strong passwords, the existing passwords may not conform to the password policy. Forcing users to reset their passwords will ensure that after logging in to the station, their password conforms to the rules.

The following steps describe how to force a user to reset their password:

1. Go to the user's property sheet view.
2. Expand the “Password Configuration” property.
3. Set the “Force Reset At Next Login” property to “True.”

The screenshot shows the 'Password Configuration' section for a user. The 'Force Reset At Next Login' property is set to 'true' and is highlighted with a red rectangular box. Other visible properties include 'Expiration' with options for 'Never Expires' and 'Expires On' (31-Jul-2016 11:59 PM EDT).

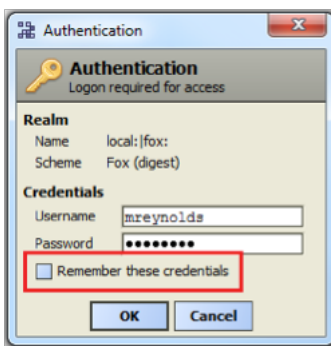
4. The next time the user logs in they will be prompted to reset their password, as shown below. The user cannot access the station until resetting the password.



To create new users with the “Force Reset At Next Login” property automatically set to “True,” verify that the “Force Reset At Next Login” property is set to “True” on the “Default Prototype.”

Leave the “Remember These Credentials” Box Unchecked

When logging in to a Niagara AX system via workbench, the login dialog includes a checkbox to “Remember these credentials.” When checked, workbench will remember the credentials and use them to automatically fill in the login dialog box the next time the user tries to log in.



This option is provided for convenience. However, it is important to be aware that, if the box is checked, anyone with access to that workbench is able to log in using those credentials. For highly sensitive systems, privileged accounts, or unsecure computers, you should always leave the box unchecked.

NOTE: Starting in NiagaraAX-3.7, there is a “Allow User Credential Caching” property on the “General” tab in the Workbench Options dialog box (Tools > Options) which defaults to true. If you set that property to false, it will prevent a user from being able to even select the “Remember these credentials” check box in the login dialog.

Account Management and Permissions

A Niagara AX station has accounts, represented by users in the UserService. It is important that these accounts are properly managed. Failure to do so can make it easier for an attacker to penetrate the system, or make it more difficult to detect that an attack has occurred.

Some steps to help correctly manage user accounts are listed below.

- Use a Different Account for Each User
- Use Unique Service Type Accounts for Each Project
- Disable Known Accounts When Possible
- Set up Temporary Accounts to Expire Automatically
- Change System Type Account Credentials
- Assign the Minimum Required Permissions
- Use Minimum Possible Number of Super Users
- Require Super User Permissions for Program Objects
- Use the Minimum Required Permissions for External Accounts

Use a Different Account for Each User

Each user account in the UserService should represent a single user. Different people should never share the same account. For example, rather than a general “managers” user that many managers could use, each manager should have their own, separate account.

There are many reasons for each user to have their own individual account:

- If each user has their own account, audit logs will be more informative. It will be easy to determine exactly which user did what. This can help detect if an account has been compromised. In the example below, it is easy to determine which changes were made by the user “admin”, and which were made by the user “mreynolds.”

test/AuditHistory						33 n
Timestamp	Operation	Target	Slot Name	Old Value	Value	User Name
10-May-13	Invoked	history:/test/AuditHistory	Clear	12 records	0 records	admin
10-May-13	Login Failure	/Services/WebService	127.0.0.1		1	admin
10-May-13	Logout	/Drivers/NiagaraNetwork/foxService/serverConnections/Session4	127.0.0.1			admin
16-May-13	Login Failure	/Drivers/NiagaraNetwork/foxService/serverConnections/Session1	127.0.0.1		1	admin
16-May-13	Login Failure	/Drivers/NiagaraNetwork/foxService/serverConnections/Session2	127.0.0.1		2	admin
16-May-13	Login	/Drivers/NiagaraNetwork/foxService/serverConnections/Session3	127.0.0.1			admin
16-May-13	Changed	/Services/UserService	requiresStrongPasswords	false	true	admin
16-May-13	Logout	/Drivers/NiagaraNetwork/foxService/serverConnections/Session3	127.0.0.1			admin
16-May-13	Login	/Drivers/NiagaraNetwork/foxService/serverConnections/Session1	127.0.0.1			admin
16-May-13	Added	/Services/UserService	mreynolds		mreynolds	admin
16-May-13	Changed	/Services/UserService/mreynolds/baja_UserPasswordConfiguration	forceResetAtNextLogin	false	true	admin
16-May-13	Changed	/Services/UserService/mreynolds	password	--password--	--password--	admin
16-May-13	Logout	/Drivers/NiagaraNetwork/foxService/serverConnections/Session1	127.0.0.1			admin
16-May-13	Login	/Drivers/NiagaraNetwork/foxService/serverConnections/Session9	127.0.0.1			mreynolds
16-May-13	Changed	/Services/WebService	httpsEnabled	false	true	mreynolds
16-May-13	Changed	/Services/WebService	httpsOnly	false	true	mreynolds
16-May-13	Logout	/Drivers/NiagaraNetwork/foxService/serverConnections/Session9	127.0.0.1			mreynolds
16-May-13	Login Failure	/Drivers/NiagaraNetwork/foxService/serverConnections/Session11	127.0.0.1		1	admin
16-May-13	Login	/Drivers/NiagaraNetwork/foxService/serverConnections/Session13	127.0.0.1			admin
16-May-13	Changed	/Services/UserService/mreynolds/baja_UserPasswordConfiguration	forceResetAtNextLogin	false	true	admin

- If an account is removed, it does not inconvenience many users. For example, if a user should no longer

have access to a station, deleting their individual account is simple. If it is a shared account, the only options are to change the password and notify all users, or to delete the account and notify all users. Leaving the account as-is is not an option – the goal is to revoke the user's access.

- If each user has their own account, it is much easier to tailor permissions to precisely meet their needs. A shared account could result in users having more permissions than they should.
- A shared account means a shared password. It is an extremely bad security practice to share passwords. It makes it much more likely for the password to be leaked, and makes it more difficult to implement certain password best practices, such as password expiration.

Each different user should have a unique individual account. Similarly, users should never use accounts intended for station-to-station connections. Station-to-station connections should have their own accounts.

Use Unique Service Type Accounts for Each Project

It is a common (bad) practice that some system integrators often use the exact same platform credentials and system (station to station) credentials on every project they install. If one system is compromised, the attacker could potentially have credentials for access to many other projects installed by the same contractor.

Disable Known Accounts When Possible

Starting in 3.7 it is possible to disable the admin account. The admin account is a known account name in a Niagara AX system. If the admin, or any other known account name for that matter, is enabled a potential hacker need only guess the user's password. However, do not disable the admin user account before you make sure that there is another super user account available. Also, you should keep the "Guest" account disabled.

Set Up Temporary Accounts to Expire Automatically

In some cases, you may need to set up an account for a user who only temporarily needs access. For example, an auditor may need an account to inspect the system. In these situations, a new account should be created and set up to expire automatically when it is no longer needed, using the "Expiration" property on the BUser. This ensures that no accounts are accidentally left enabled.

To set up an account to expire, follow the instructions below.

1. *Go the UserService, and create a new User.*
2. *In the user creation pop up dialog, set the "Expiration" property to the date the user will no longer require access.*

Assign the Minimum Required Permissions

When creating a new user, think about what the user needs to do in the station, and then assign the minimum permissions required to do that job. For example, a user who only needs to acknowledge alarms does not need access to the UserService or the WebService. Giving non-required permissions increases the chance of a security breach. The user might inadvertently (or purposefully) change settings that they should not change. Worse, if the account is hacked, more permissions give the attacker more power.

Create new categories

In the Category Service, you should create categories as needed to ensure that users have access only to what they absolutely need.

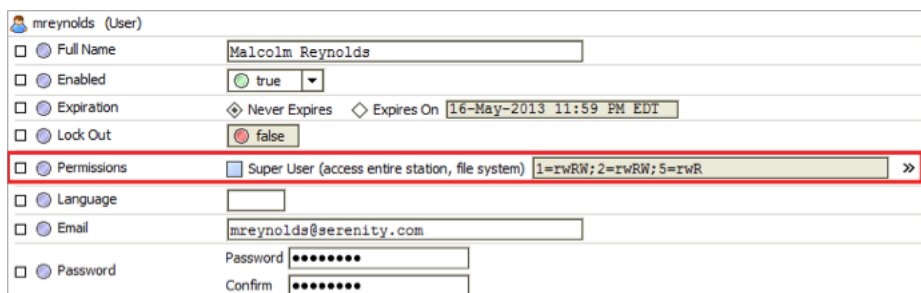
Consider the following example of how you can minimize the risk of using the Niagara AX TunnelingService:

If a station is using the TunnelService (if not used, disable it!) this can increase security risk because Station login from the Niagara client-side applications (serial tunnel and Lon tunnel) uses “basic authentication.” This means that the password is transmitted in the clear. You can minimize this risk by using a special category to which you assign only the TunnelService component. Then create a new station user, and assign permissions only on that one category (admin write). By using only this (new) user for login from the serial tunnel or Lon tunnel client application, tunneling is allowed, but with minimal impact if credentials are compromised.

For more information on setting categories and permissions, refer to the “Security model overview” section and various subsections in the *NiagaraAX User Guide*.

Use Minimum Possible Number of Super Users

Only assign Super User permissions when absolutely necessary. A Super User is an extremely powerful account – it allows complete access to everything. A compromised Super User account can be disastrous. Only the system administrator should have access to the account.



mreynolds (User)	
☐ Full Name	Malcolm Reynolds
☒ Enabled	true
☐ Expiration	Never Expires Expires On 16-May-2013 11:59 PM EDT
☐ Lock Out	false
☐ Permissions	Super User (access entire station, file system) 1=zWRN; 2=zWRN; 5=zWR
☐ Language	
☐ Email	mreynolds@serenity.com
☐ Password	Password Confirm

Although it can be very tempting to take the easy route and check the Super User box for each user, doing so puts your system at risk. Instead, create users with the appropriate permissions.

Require Super User Permissions for Program Objects

Program Objects are extremely powerful components in a Niagara AX station. Similar to Super User permissions, they can give a user complete control over a station, and should only be editable by the Super User. Allowing any other user to edit Program Objects defeats the purpose of setting permissions.

While Program Objects are restricted to Super Users by default, it is possible to lift this restriction by editing the <niagara_home>\lib\system.properties file. To ensure that the restriction is in place, verify that the line “niagara.program.requireSuperUser=false” is commented out (using the # character) as shown below:

```
# When this line is set to false, the restriction that only
# super users can add/edit program objects and robots in a
# running station will be lifted. The default value is true,
# meaning that only super users can add/edit program objects (and robots).
#niagara.program.requireSuperUser=false
```

NOTE: Although only Super Users should be allowed to edit Program Objects, it can be acceptable for other users to invoke the Program Object’s “Execute” action.

Use the Minimum Required Permissions for External Accounts

Some stations use accounts for external servers – for example, an RdbmsNetwork with a SqlServerDatabase must specify a username and password for the SQL server. This account is used when connecting to the server to read from or write to the database.

NOTE: References in this section are to permissions on the external server, and not permissions on the Niagara AX station.

These and any other external accounts should always have the minimum permissions needed for the required functionality. That way, if the station is compromised or an exploit is discovered, the external server is better protected: an attacker gaining control of an SQL administrator user could wreak havoc, reading confidential information or deleting important data; on the other hand, an attacker gaining control of a restricted user has much less power.

When configuring a Niagara AX station, be sure to understand exactly what tasks the external account needs to be able to perform, and create a user with the minimum rights and permissions required to perform those tasks.

Authentication

Niagara AX stations offer several authentication policy options. These options determine how a client talks to the station and how the user’s password is transmitted to the station for proof of identity. Be sure to use the strongest authentication policies to increase protection for user passwords, keeping those accounts safer from attacks.

The following steps ensure the strongest authentication is used.

- Use “Digest” Authentication in the FoxService
- Set the FoxService Legacy Authentication to “Strict”
- Use “cookie-digest” Authentication in the WebService

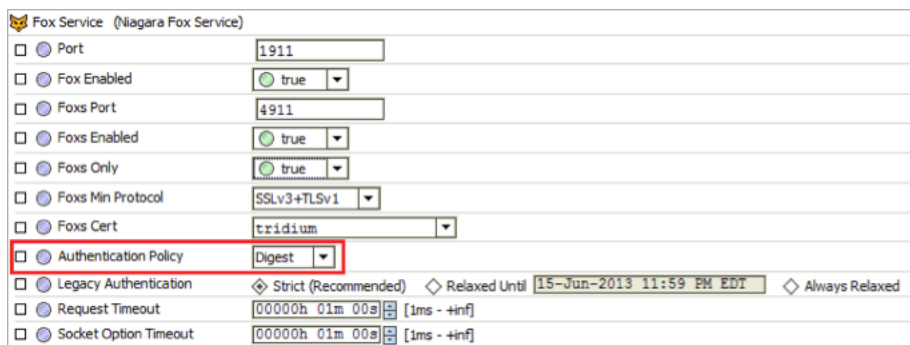
Use “Digest” Authentication in the FoxService

The FoxService allows you to set two different authentication policies. With **basic** authentication, the user’s password is transmitted to the station in the clear, without any kind of processing. With **digest** authentication, the user’s password is specially processed and is never actually sent to the station. In addition, the station must provide proof of its own identity before authentication is successful.

Unless otherwise required, the authentication policy should *always* be set to Digest. One exception to this is use of the LdapUserService, which cannot do digest authentication for LDAP users.

To set the authentication policy to Digest, do the following:

1. *Open the Drivers > NiagaraNetwork > Fox Service’s property sheet.*
2. *Set the “Authentication Policy” property to “Digest.”*



Fox Service (Niagara Fox Service)	
Port	1911
Fox Enabled	true
Foxs Port	4911
Foxs Enabled	true
Foxs Only	true
Foxs Min Protocol	SSLv3+TLSv1
Foxs Cert	tridium
Authentication Policy	Digest
Legacy Authentication	Strict (Recommended) Relaxed Until 15-Jun-2013 11:59 PM EDT Always Relaxed
Request Timeout	00000h 01m 00s [1ms - +inf]
Socket Option Timeout	00000h 01m 00s [1ms - +inf]

3. *Save the changes.*

NOTE: In later releases of NiagaraAX-3.5, 3.6, and 3.7, Digest is the default setting.

Set the FoxService Legacy Authentication to “Strict”

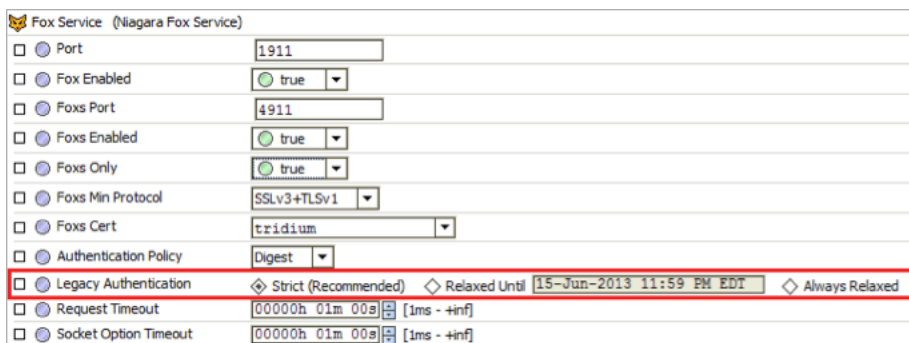
Starting in NiagaraAX-3.7u1 (Update 1), 3.6u4 (Update 4), and 3.5u4 (Update 4), the digest authentication policy has been improved. However, because of these changes, a newer station cannot authenticate clients attempting to use the older digest MD5 algorithm.

To enable stations with digest authentication to talk to older clients, the “Legacy Authentication” property has been added to the FoxService. If set to “Always Relaxed”, or “Relaxed Until”, the station will degrade authentication to basic to allow the older client to authenticate. If the client can do the new digest, the new digest is used. If the client cannot do the new digest, basic is used. It only degrades for older clients. In the “Relaxed Until” case, it only allows this to happen until the specified date.

This feature is only intended for temporary use, to allow stations to continue to communicate while they are in the process of being upgraded.

To set the “Legacy Authentication” to “Strict”, follow these steps:

1. Open the Drivers > NiagaraNetwork > FoxService's property sheet.
2. Set the “Legacy Authentication” property to “Strict.”



Fox Service (Niagara Fox Service)	
Port	1911
Fox Enabled	true
Foxs Port	4911
Foxs Enabled	true
Foxs Only	true
Foxs Min Protocol	SSLv3+TLSv1
Foxs Cert	tridium
Authentication Policy	Digest
Legacy Authentication	Strict (Recommended) Relaxed Until 15-Jun-2013 11:59 PM EDT Always Relaxed
Request Timeout	00000h 01m 00s [1ms - +inf]
Socket Option Timeout	00000h 01m 00s [1ms - +inf]

3. Save the changes.

Use “cookie-digest” Authentication in the WebService

Similarly to the FoxService, the WebService has three different authentication policies available: basic, cookie, and cookie-digest. With cookie authentication, the user’s password is transmitted to the station in the clear, without any kind of processing. With cookie-digest authentication, the user’s password is specially processed and is never actually sent to the station. In addition, the station must provide proof of its own identity before authentication is successful.

Unless otherwise required, the authentication policy should always be set to cookie-digest. One exception to this is use of the LdapUserService, which cannot use cookie-digest authentication for LDAP users.

To set the authentication policy to (the default) cookie-digest option, follow these steps:

1. Open the Services > WebService's property sheet.
2. Set the “Authentication Scheme” property to “cookie-digest.”

WebService (Web Service)	
☐ Status	[ok]
☐ Fault Cause	
☐ Enabled	☒ true
☐ Http Port	80
☐ Http Enabled	☒ true
☐ Https Port	443
☐ Https Enabled	☒ true
☐ Https Only	☒ true
☐ Https Min Protocol	SSLv3+TLSv1
☐ Https Cert	tridium
☐ Authentication Scheme	Cookie Digest
☐ Gzip Enabled	☒ true

3. Save the changes.

TLS & Certificate Management

NOTE: In late 2014, the POODLE vulnerability was discovered in SSLv3. As a result, SSLv3 support was removed from NiagaraAX-3.8u1. For older versions of Niagara AX that still support SSL, SSLv3 should be turned off by selecting the "TLSv1" option for the "Ssl Min Protocol" property in the Web and Fox Services, and for the "Protocol" option in the "Platform SSL Settings" dialog box.

Transport Layer Security (TLS) provides communication security over a network by encrypting the communication at a lower level than the actual data being communicated. This allows secure transmission of unencrypted data (for example, the username and password in fox Basic authentication) over an encrypted connection. TLS as a protocol replaces its predecessor, Secure Sockets Layer (SSL); however, because TLS originally evolved from the SSL standard, the terms "TLS" and "SSL" are often used interchangeably. Although many people still refer to TLS as "SSL", it is important to know that the latest version of SSL as a protocol (SSLv3) is not considered secure, and it is important to use the latest version of TLS available.

Using TLS protects data from anyone who might be eavesdropping and watching network traffic. It also provides proof of identity, so that an attacker cannot impersonate the server to acquire sensitive data. When possible, **always** use TLS.

Niagara AX provides several opportunities for using TLS. Starting in NiagaraAX-3.7, a number of additional options are available. You should use these options whenever they are feasible. Niagara AX TLS options are listed below:

- Enable Platform TLS Only (3.7 or higher)
- Enable Fox TLS Only (3.7 or higher)
- Enable Web TLS Only
- Enable TLS on Other Services
- Set Up Certificates

NOTE: NiagaraAX-3.6 and JACE2/4/5 hosts in NiagaraAX-3.7 and NiagaraAX-3.8 previously supported SSLv3 for the WebService. However SSLv3 has been shown to be broken, and support for SSL in the legacy crypto module has been removed. Hosts that do not support TLS should be upgraded to a platform and version that supports TLSv1.0 or better.

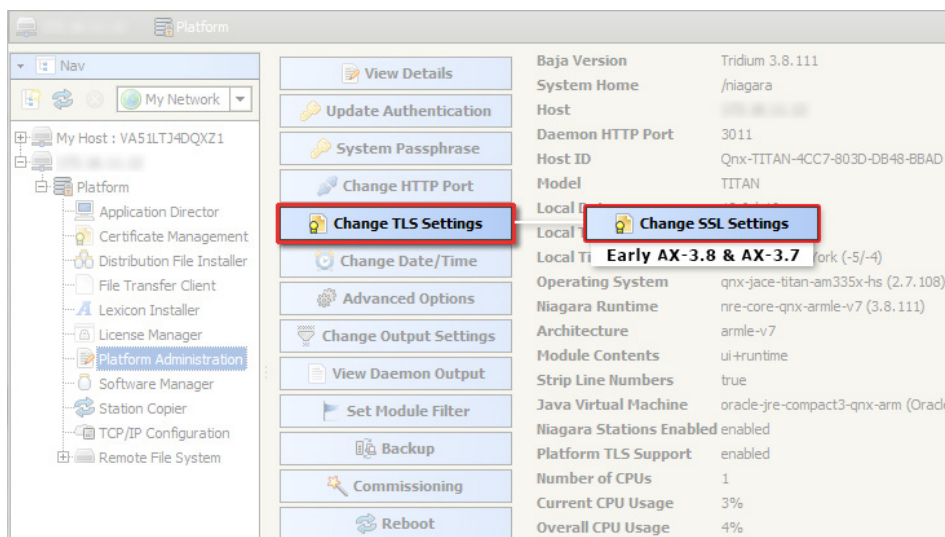
Enable Platform TLS Only (3.7 or higher)

Starting in NiagaraAX-3.7, TLS can be enabled for platform connections.

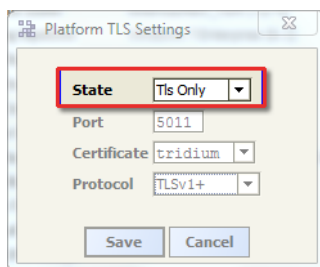
To enable platform TLS, do the following:

NOTE: The following images are from NiagaraAX-3.8U1. Earlier AX-3.8 and AX-3.7 interfaces display a "Change SSL Setting" button. Either button is valid for configuring TLS settings.

1. Open a platform connection.
2. Navigate to the "Platform Administration" view, and select "Change TLS Settings" ("Change SSL Settings" from pre AX-3.8U1 installations).



3. A "Platform TLS Settings" dialog opens. Select "TLS Only" ("SSL Only" from pre AX-3.8U1 installations) from the "State" drop down menu.



4. Adjust the other fields as necessary.
 - **Port.** The default port (5011) is generally acceptable, but may need to be changed due to IT constraints.
 - **Certificate.** This allows you to select the certificate you want to use for TLS Note: the default self-signed tridium certificate only provides encryption and does not provide for server identity verification. Refer to the *NiagaraAX SSL Connectivity Guide* for more details on certificates.

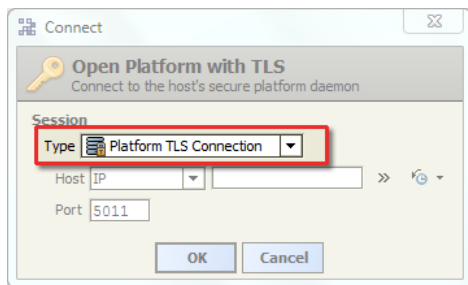
- **Protocol.** This determines whether to use SSLv3 or TLSv1. NiagaraAX-3.8u1 only supports TLSv1 or better. If using a version that still supports SSLv3, this should be set to TLSv1 only, since SSLv3 has been shown to have vulnerabilities.

5. Click the “Save” button. Close the platform connection.

NOTE: If “State” is set to “Enabled” rather than “TLS Only,” regular platform connections (not over TLS) are still be permitted. Unless absolutely required, this should not be allowed, because it places the burden of remembering to use TLS on the user initiating the connection – this can easily be forgotten, compromising security.

With TLS enabled for platform connections, a platform connection over TLS can be opened, as described below:

1. From the File menu, open the “Open Platform” dialog box.
2. Under the “Session” section, change the “Type” field to “Platform TLS Connection.” Note that the dialog is updated.

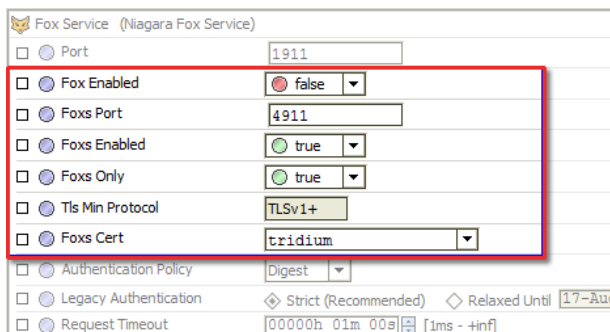


3. Enter the IP, port and credentials for the platform and click “OK.”

Enable Fox TLS Only (3.7 or higher)

Starting in NiagaraAX-3.7, TLS can be enabled for Fox connections, as outlined below.

1. Open a station connection.
2. Open Drivers > NiagaraNetwork > FoxService's property sheet.
3. Set “Foxs Enabled” to “true.”
4. Set “Foxs only” to “true.”



5. *Adjust the other Foxs settings as necessary.*

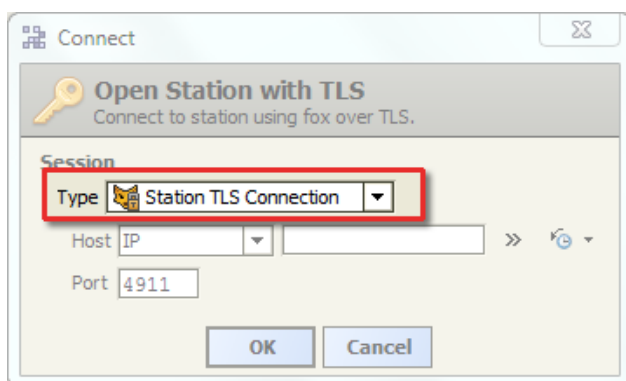
- **Foxs Port.** The default port (3911) is generally acceptable, but may need to be changed due to IT constraints.
- **TLS Min Protocol.** This determines whether to use SSLv3 or TLSv1. NiagaraAX-3.8u1 only supports TLSv1 or better. If using a version that still supports SSLv3, this should be set to TLSv1 only, since SSLv3 has been shown to have vulnerabilities.
- **Foxs Cert.** This allows you to select the certificate you want to use for TLS. See the *NiagaraAX SSL Connectivity Guide* for more details on certificates.

6. *Save the settings and close the station connection.*

NOTE: If "Foxs only" is not set to true, regular fox connections (not over TLS) are permitted. Unless absolutely required, this configuration should not be allowed, because it places the burden of remembering to use TLS on the user initiating the connection. This can easily be forgotten, compromising security. Leaving the "Fox Enabled" property set to true with "Foxs Only" also set to true provides a redirect to the Foxs port if a client attempts to make an unsecure Fox connection.

Now that TLS is enabled, a Foxs (Fox over TLS) connection can be opened, as described below:

1. *Open the "Open Station" dialog box.*
2. *Under the "Session" section, change the "Type" field to "Station TLS Connection." Note that the dialog box is updated.*



3. *Enter the IP, port and credentials for the station and click "OK".*

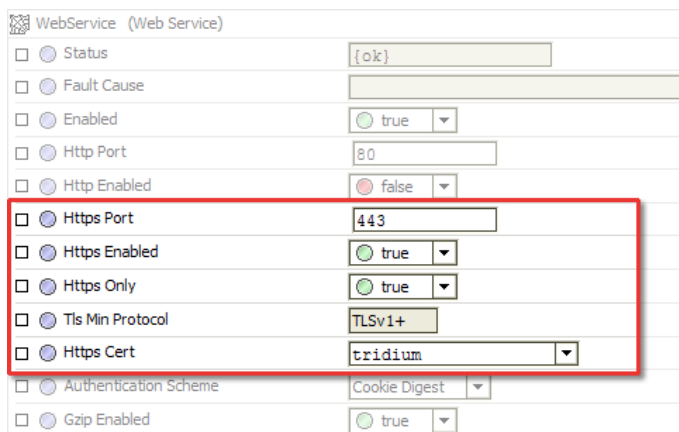
NOTE: A fox connection over TLS has a tiny lock on the fox icon (🦊).

Enable Web TLS Only

Some of the information in this section is contingent on the type of Java Virtual Machine (IBM J9 or Sun Hotspot) being used by controllers running Niagara AX.

The steps to follow to enable TLS over HTTP are outlined below:

1. *Open a station connection.*
2. *Open Services > WebService's property sheet.*
3. *Set the "Https Enabled" property to "true."*
4. *Set the "Https Only" property to "true."*



WebService (Web Service)	
Status	{ok}
Fault Cause	
Enabled	true
Http Port	80
Http Enabled	false
Https Port	443
Https Enabled	true
Https Only	true
Tls Min Protocol	TLSv1+
Https Cert	tridium
Authentication Scheme	Cookie Digest
Gzip Enabled	true

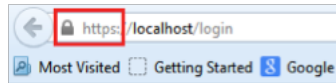
5. *Adjust the other Https settings as necessary.*
 - **Https port.** The default port (443) is generally acceptable, but may need to be changed due to IT constraints.
 - **TLS Min Protocol (NiagaraAX-3.7 and the Sun Hotspot JVM only).** This does not apply to controllers using IBM J9 JVM). This determines whether to use SSLv3 or TLSv1. NiagaraAX-3.8u1 only supports TLSv1 or better. If using a version that still supports SSLv3, this should be set to TLSv1 only, since SSLv3 has been shown to have vulnerabilities.
 - **Https Cert (NiagaraAX-3.7 and the Sun Hotspot JVM only).** This does not apply to controllers using IBM J9 JVM). This property allows you to select the certificate you want to use for TLS. Note that the default self signed "tridium.certificate" only provides encryption and does not provide server identity verification. See the *NiagaraAX SSL Connectivity Guide* for more details on certificates.
6. *Save the settings.*

NOTE: That if "Https only" is not set to true, regular http connections (not over TLS) will still be permitted. Unless absolutely required, this should not be allowed, because it places the burden of remembering to use TLS on the user initiating the connection – this can easily be forgotten, compromising security.

Now that TLS is enabled, an HTTPS connection can be opened. Here's how:

1. *Open a browser.*
2. *Navigate to the station's login page. If the server's certificate was signed by a valid CA then you probably will not see a prompt.*
3. *If prompted, you need to make your decision on whether or not to accept the Certificate based on an understanding of the circumstances. See the NiagaraAX SSL Connectivity Guide for more details.*

4. *Note that you now have an https connection.*



SPECIAL NOTE FOR JACE-2/4/5 CONTROLLERS:

In NiagaraAX-3.6, NiagaraAX-3.5, or any J9 JVM host (JACE-2/4/5, regardless of version), only SSLv3 is supported (via the older crypto module). Because SSLv3 has been shown to be broken, these system should be upgraded to a system that supports TLSv1 or better. Later versions of Niagara AX do not support the older crypto module at all.

The following points concern using Web TLS only in NiagaraAX-3.6, NiagaraAX-3.5, or any J9 JVM host (JACE-2/4/5, regardless even if 3.7).

- *For security purposes, Hx access to the station is preferred over Wb Web Profile access.*
- *Both profiles use HTTPS to pass user credentials, however, with Wb Web Profile, some data (not user credentials) is passed over an insecure Fox connection.*

Enable TLS on Other Services

There are a number of services in Niagara AX that communicate with an outside server. For example, the EmailService's OutgoingAccount and IncomingAccount both contact an email server. This connection is not the same as the fox or http connection used by the client to talk to the station, and TLS is handled separately for these types of connections. When setting up a new service on a station, check to see if it includes an TLS option. If TLS is an option, make sure that it is enabled. If needed, contact the IT department and make sure that the server the station needs to talk to supports TLS.

See *Niagara^{AX} SSL Connectivity Guide* and *Niagara^{AX} User Guide* for details about setting up email with TLS features.

Set Up Certificates

Starting in NiagaraAX-3.7, new tools are included to help with certificate management. Certificates are required for TLS, and should be set up properly.

NOTE: Default certificates are self signed and can only be used for encryption, not for server identity verification. This is true for both the legacy crypto features and the new 3.7 and up TLS features.

There are many things to consider when setting up certificates, and a full discussion is beyond the scope of this document. See the *Niagara^{AX} SSL Connectivity Guide* for more information about correctly setting up certificates for a Niagara^{AX} system.

JACE-8000 Settings

The JACE-8000 comes with additional security settings that must be appropriately configured. This section describes some of the security settings specific to the JACE-8000 platform.

System Password Management

The JACE-8000 uses an SD card as its primary storage media for all data and configuration related to the Niagara installation. Some of the stored data (e.g. passwords) are sensitive and must be protected, for example from someone with physical access to the JACE-8000, or with access to the SD card if it has been removed from the unit.

In order to protect it, the sensitive data is encrypted using the system passphrase. The system passphrase is not associated with a user; it is used by the system to encrypt files. Because the passphrase is known by a human user, the data can be moved to another unit and decrypted there, provided the new system is provided with the correct system passphrase.

Use TLS to set the system passphrase

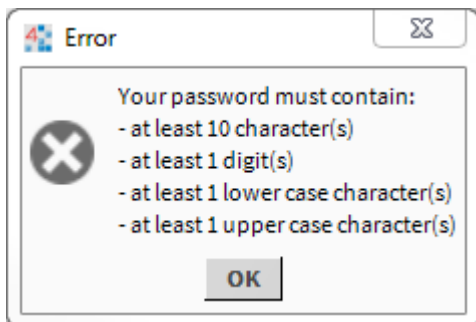
The system passphrase protects sensitive data; it must be protected. One way an attacker can attempt to acquire the system passphrase is by sniffing network traffic: when setting the passphrase via a platform connection, the passphrase is sent across in cleartext. As a result, an attacker watching network traffic would be able to easily acquire the passphrase and the sensitive data would be compromised.

TLS should always be used when setting the system passphrase. This wraps the entire communication in a layer of encryption, preventing the attacker from reading the passphrase as it is set.

Choose a truly strong passphrase

The system passphrase is used to protect important data. As a result, a strong passphrase should be selected. The system enforces the following passphrase requirements (see below):

- At least 10 characters long



- At least 1 digit
- At least 1 lower case character
- At least 1 upper case character

As described in “*Stronger Passwords*” on page 6, passphrase strength requirements are not sufficient to ensure that actually strong passphrases are used. For example, “Password10” satisfies all the requirements,

but is actually a weak, easily crackable passphrase. When creating a passphrase, the following guidelines can help generate stronger passwords:

- A random string of characters, including digits and uppercase, lowercase and special characters, (e.g. s13pj96t!cD) is typically a strong password. However, these can be hard to remember.
- A long, nonsensical sentence (e.g. “I happily tarnished under 21 waterlogged potatoes, which meet up on Sundays”) can be used as is. For systems that restrict password length, it can be contracted to include only the first character of each word (e.g. “lhtu21wp,wmuoS”). These are difficult for attackers to guess, but are typically easy (albeit silly) for users to remember.

Note: when picking a sentence as a passphrase, it is best to avoid well-known phrases and sentences, as these may be included in dictionary attacks (e.g. “Luke, I am your father”).

- A string of random words (e.g. “coffee Strange@ Halberd 11 tortoise!”) provides a much longer password than a single word or a random string of characters. However, password crackers are becoming more aware of this technique, and inserting few random numbers and symbols in there can help.

Protect the system passphrase

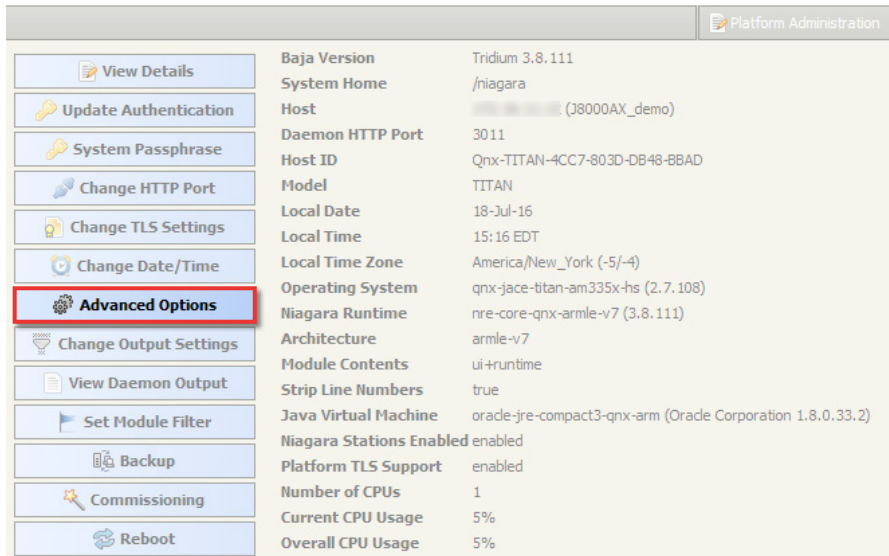
In addition to picking a strong system passphrase, users should take care to protect the system passphrase. The passphrase should not be written down or placed on a sticky note on the JACE-8000. If forgetting the passphrase is truly a concern, it should be recorded in a proper key management system, or written down and locked away in a truly secure location (e.g. a safe).

Disable SSH/SFTP

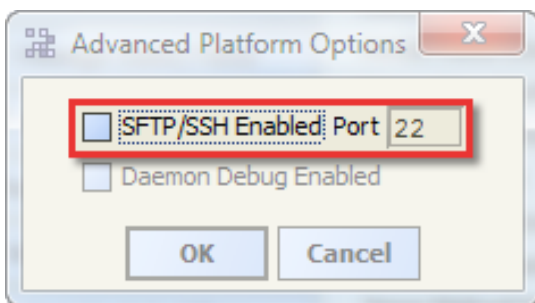
SFTP (Secure File Transfer Protocol) and SSH (Secure Shell) access to a JACE-8000 are disabled by default and should remain disabled unless necessary for troubleshooting or as directed by Tridium technical support. This helps prevent unauthorized access to the JACE. Enabling SFTP or SSH on a JACE-8000 poses a very significant security risk.

To ensure that SFTP and SSH are disabled on a JACE-8000, follow these steps:

1. *Open a platform connection to the JACE-8000 controller.*
2. *In the Platform Administration view, click on “Advanced Options.”*



3. When the “Advanced Platform Options” dialog box opens, make sure that “SFTP/SSH Enabled” box is not selected.



Additional Settings

In addition to the settings discussed in previous sections, there are a few general settings to configure in order to secure a Niagara AX system. These don't fall under a specific category like TLS or passwords, but are nonetheless important to security.

- Disable FTP and Telnet
- Disable Unnecessary Services
- Configure Necessary Services Securely
- Blacklist Sensitive Files and Folders

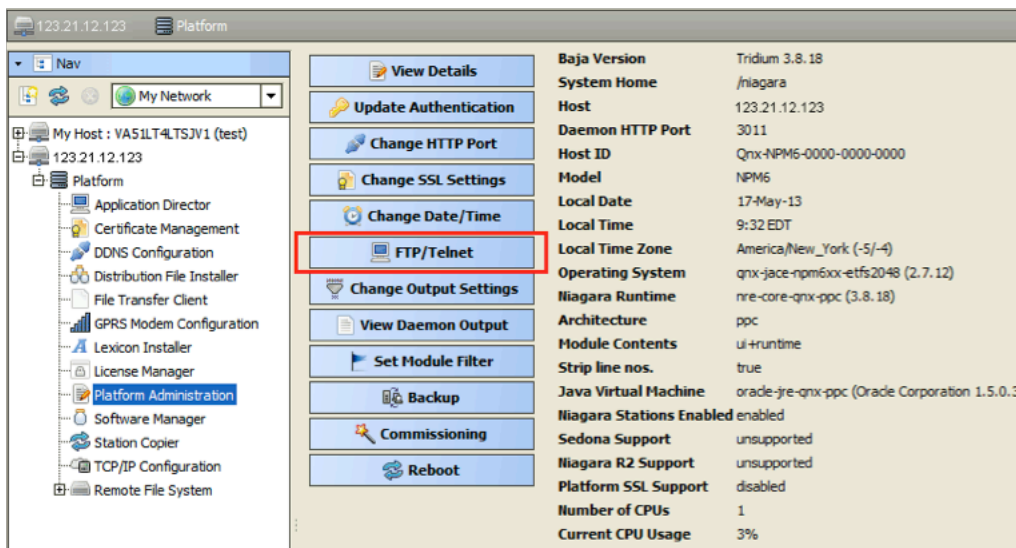
Update Niagara AX to the Latest Release

Disable FTP and Telnet

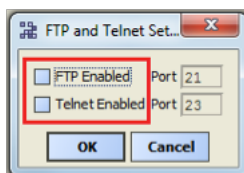
FTP (File Transfer Protocol) and Telnet access to a JACE are disabled by default and should *remain disabled unless necessary for troubleshooting or as directed by Tridium technical support*. This helps prevent unauthorized access to the JACE. Enabling FTP or Telnet on a JACE poses a very significant security risk.

To ensure that FTP and Telnet are disabled on a JACE, follow these steps:

1. Open a platform connection to the JACE controller.
2. In the Platform Administration view, click on “FTP/TELNET.”



When the “FTP and Telnet Settings” dialog box opens, make sure that the “FTP Enabled” and “Telnet Enabled” boxes are not selected.

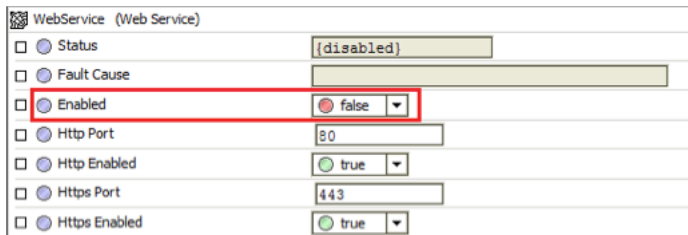


Disable Unnecessary Services

When setting up a Niagara AX station, either after creating a new station or copying an existing one, many services may already be installed and enabled in the Services folder. However, not every station has the same requirements. Services that are not required for what the station needs to do should be removed or disabled. This helps improve security by providing fewer openings for a potential attacker to exploit.

For example, if the station is not intended to be accessed via the web, the WebService you should disable it. This will prevent potential attackers from using the web to attempt to penetrate the station. The same consideration should be given to the TunnelService and others. See the *Niagara^{AX} Drivers Guide* for information about minimizing possible risks involved with tunneling.

To disable a service, either remove it from the station by deleting it, or go to the service's property sheet and look for an "Enabled" property. If one exists, set it to false, as shown below for WebService, or possibly for unused TunnelService.



The screenshot shows the 'WebService (Web Service)' property sheet. The 'Enabled' property is highlighted with a red rectangle and is set to 'false'. Other properties include 'Status' (disabled), 'Fault Cause', 'Http Port' (80), 'Http Enabled' (true), 'Https Port' (443), and 'Https Enabled' (true).

Property	Value
Status	{disabled}
Fault Cause	
Enabled	false
Http Port	80
Http Enabled	true
Https Port	443
Https Enabled	true

Figuring out what services are required means planning ahead of time how the station is intended to be used. Remember, a service can always be added or enabled, so it is best to start with only the services known to be required, and add services later as necessary.

Configure Necessary Services Securely

If a service is required, care should be taken to configure that service securely. Different services have different settings affecting security, and the relevant documentation should be consulted when configuring a new service.

For example, when configuring the WebService, in addition to configuring TLS, the following settings should be on considered:

- The 'X Frame Options' property should be set to 'SameOrigin' or 'Deny' when possible to protect against Cross Frame Scripting (XFS) attacks. This is available in 3.6u4, 3.7u1, 3.8 and 4+.
- 'Show Stack Traces' should be set to false unless specifically debugging an issue, as a stack trace could reveal information that an attacker could use. This is available in 3.6.u4, 3.7u1, 3.8 and 4+.

Blacklist Sensitive Files and Folders

In NiagaraAX-3.5u4, 3.6u4 and 3.7u1, and 3.8 a blacklist feature is available. When you implement this feature, files and folders on the blacklist are not accessible remotely through the station. This helps protect sensitive files from being tampered with. For example, if an attacker is able to get into the station using a web connection, access to any file in the blacklist is still denied.

Some folders are always blacklisted, such as the following: /backups, /bin, /daemon, /files, /jre, /modules, /registry, /security, /users and /workbench.

Refer to the "system.properties security notes" section in the *Niagara^{AX} Platform Guide* for more details about

blacklisting and more notes and cautions about editing the system.properties file.

Additional files may be blacklisted by editing the system.properties files, as described below:

1. *Open the system.properties file.*
2. *Uncomment the “niagara.remoteBlacklist.fileNamePatterns” line and add any file patterns that should be blacklisted (for example, *.bog).*

```
# The following property allows for specification of additional
# file name patterns to blacklist from remote station access.
# File name patterns are delimited by a semicolon, and follow the format
# defined in javax.baja.util.PatternFilter. For example, a value of
# *.txt;*.xml would restrict any text or xml file from being accessed
# remotely through the station (i.e. from the web or through a fox
# connection in Workbench).
niagara.remoteBlacklist.fileNamePatterns=*.bog
```

3. *Uncomment the “niagara.remoteBlackList.filePaths” line and add any folders that should be blacklisted (for example, !lib)*
4. *A station must be restarted before changes to system.properties become effective.*

```
# The following property allows for specification of additional
# file paths to blacklist from remote station access (i.e. from the
# web or through a fox connection in Workbench).
# File paths are delimited by a semicolon, and follow the body format
# defined in javax.baja.file.FilePath. For example, a value of
# !licenses;!modules would restrict access to the licenses and modules
# directories under the Niagara sys home.
niagara.remoteBlacklist.filePaths=!lib
```

The additional file patterns or folders to blacklist depend on the particular Niagara AX installation. Think about what needs to be protected and does not absolutely need to be accessed remotely via a fox or web connection.

Update Niagara AX to the Latest Release

Niagara AX updates often include a number of important fixes, including security fixes. Niagara AX systems should always be updated as soon as possible to ensure the best available protection. This is very important. Older releases may have known vulnerabilities – these are fixed as soon as possible, but if a system is not updated, it does not get the fixes.

External Factors

In addition to station and platform settings, there are some external factors to consider when securing a Niagara AX system.

- Install JACEs in a Secure Location
- Make Sure that Stations Are Behind a VPN

Install JACEs in a Secure Location

Restricting physical access to JACE controllers is essential to security. If an attacker can physically connect to the JACE using a cable, they can gain complete control of the system. This could potentially be disastrous. Keep JACEs secure in a locked room with restricted access.

Make Sure that Stations Are Behind a VPN

A station exposed to the Internet is a station at risk. Anyone who discovers the station's IP address can attempt an attack, either to gain access to the system or to bring the system down. Even stations that have been configured to use TLS only are at risk for a denial-of-service attack. Keeping stations behind a properly configured VPN ensures that they are not exposed, reducing the system's attack surface.

Do not assume that because you have not shared the station's IP address with anyone that it cannot be discovered – that is not the case. A clever attacker can discover exposed Niagara AX systems without knowing the IP addresses beforehand.

This document is provided to assist you in optimizing the security of the Niagara AX Framework features available to you as a licensee of the Niagara AX Framework. Nothing contained in it constitutes either a representation or a warranty, nor is it intended to provide assurance against security breaches, as that is not possible to do. Furthermore, this guide is not a substitute for advice of an information technology professional who is knowledgeable about your specific computing environment. Nothing in this guide shall be deemed to expand or modify in any way any of the provisions of the End User License Agreement applicable to the Niagara AX Framework.

© 2016 Tridium, Inc.

Niagara, Niagara Framework, Niagara AX, Workbench and JACE are trademarks of Tridium, Inc.